Bizboard Help Guide: Google Authenticator Setup

Step-by-step instructions for integrating Google Authenticator (Two-Step Verification / TOTP) on Login and Settings

---

1. Overview & Prerequisites

Bizboard supports standard **Two-Step Verification (TOTP, RFC 6238)** to protect your company books. When enabled, signing in requires both your password (or mobile OTP) and a 6-digit code generated on your phone.

- **Supported Authenticator Apps:** Google Authenticator (Android & iOS), Microsoft Authenticator, Authy, or 1Password.
- **Where to install Google Authenticator:** Download *Google Authenticator* from the Google Play Store (Android) or Apple App Store (iPhone/iPad).
- **Who must enrol:** Any user can enable Two-Step Verification in **Settings** → **Users**. When money-role enforcement is active, **Owners**, **Accountants**, and users with **Post Journals** permission are prompted to set it up automatically during sign-in.

2. Setting Up Google Authenticator on the Sign-In Screen (/login)

If your account requires Two-Step Verification before you can access Bizboard, the **Set up two-step verification** screen appears right after you enter your email and password on `/login`.

1. **Start Setup:** On the Bizboard *Set up two-step verification* screen, click the **Turn on** button. Bizboard will display a **QR Code** and a read-only **Setup key**.
2. **Open Google Authenticator on your phone:** Tap the **+** button in the bottom-right corner.
3. **Link your account (choose one method):**
   • **Option A — Scan QR Code (Recommended):** Tap **Scan a QR code** in Google Authenticator and point your phone camera at the QR code on the Bizboard screen.
   • **Option B — Enter Setup Key Manually:** Tap **Enter a setup key** in Google Authenticator and fill in:
   – *Account name:* `BizBoard (your-email)`
   – *Your key:* Copy/type the **Setup key** shown on Bizboard
   – *Type of key:* Select **Time based**, then tap **Add**.
4. **Confirm the 6-digit code:** Google Authenticator will now show a 6-digit code that refreshes every 30 seconds. Type that 6-digit number into **Enter the 6-digit code to confirm** on Bizboard and click **Confirm and turn on**.
5. **Save your 10 Recovery Codes:** Bizboard immediately displays **10 single-use recovery codes** (format: `XXXXX-XXXXX`). Write them down, print them, or store them in a password manager, then click **I have saved them**.
6. **Complete Sign-In:** Wait a few seconds for Google Authenticator to roll over to the **next** 6-digit code (each code can only be used once), then sign in with your password and the new 6-digit code.

> **Important — Save Your Recovery Codes Now:** Your 10 recovery codes are shown **only once** when you confirm setup. The server stores only encrypted hashes and will never display the same list again.

3. Setting Up Google Authenticator from Inside Bizboard (Settings → Users)

If you are already signed in and want to turn on Two-Step Verification for your account:

1. Navigate to **Settings** → **Users** (`/settings/users`) in the left sidebar.
2. At the top of the page, locate the **Two-step verification** panel (the status chip will say **Off**).
3. Click **Turn on** to generate your QR code and **Setup key**.
4. Scan the QR code (or type the **Setup key** as a **Time based** key) in the **Google Authenticator** app.
5. Enter the 6-digit code from your phone into **Enter the 6-digit code to confirm** and click **Confirm and turn on**.
6. Copy and store your 10 recovery codes safely, then click **I have saved them**. The status chip will change to **On**.

4. Daily Sign-In & Using Recovery Codes

Signing in with Google Authenticator

1. Go to `/login` and sign in with your **Email & password** (or **Mobile OTP**).

2. When prompted with **Two-step verification**, open Google Authenticator on your phone.
3. Enter the 6-digit code into **Authentication code** and click **Verify and sign in**.

Signing in if you lost your phone (Using a Recovery Code)

1. On the **Two-step verification** step of `/login`, click **Use a recovery code instead**.
2. Enter one of your saved 10-character recovery codes (e.g., `ABCDE-23456`) into the **Recovery code** field.
3. Click **Verify and sign in**. That recovery code is now consumed and cannot be used a second time.

5. Regenerating Recovery Codes or Turning Off Two-Step Verification

In **Settings** → **Users** (`/settings/users`), the **Two-step verification** panel shows how many unused recovery codes you have left (e.g., *10 recovery codes left*).

- **To generate 10 new recovery codes:** Click **Turn off / Get new recovery codes**, enter **Your password** and a current 6-digit **Authentication code** from Google Authenticator, then click **Get new recovery codes**. All previous recovery codes are immediately invalidated.
- **To turn off Two-Step Verification:** Click **Turn off / Get new recovery codes**, enter **Your password** plus either a 6-digit **Authentication code** OR one unused **Recovery code**, then click the red **Turn off** button.

6. Troubleshooting & Technical Reference

Issue / Message	Cause	How to Fix
That code is not valid / That code did not work	1) Phone clock is out of sync. 2) You reused the same 6-digit code twice within the same 30-second window.	1) Enable **Automatic date & time** in your phone settings. 2) Wait up to 30 seconds for Google Authenticator to show a new 6-digit code and try again.
Too many login attempts (429 Locked)	5 consecutive wrong MFA or recovery codes were entered.	Wait for the security lockout cooldown to expire, then sign in again with a fresh code.
Enrolment session expired. Sign in again.	The login-time enrolment token expires after 10 minutes (or 8 attempts).	Go back to `/login`, enter your email and password again, and click **Turn on**.
Your sign-in session expired. Enter your password again.	More than 5 minutes passed between entering your password and submitting the 6-digit code.	Click **Back to sign in**, re-enter your password, and enter the current 6-digit code.
Lost phone AND lost all recovery codes	No second factor is available to the user.	Ask your server administrator to run the break-glass host command: `python manage.py reset_user_mfa --email user@company.com --yes`

Manual TOTP Parameters (for any Authenticator App)

Issuer: `BizBoard` | **Algorithm:** `HMAC-SHA1` | **Digits:** `6` | **Period (Step):** `30 seconds` | **Clock Drift Tolerance:** `±1 step (30s)`